Перушкин. Тема: Разработка интеллектуальной системы оценки и регулирования киберрисков серверной инфраструктуры Linux при эксплуатации ошибок конфигурирования сервисов

№	Противоречия между	Задачи исследования	Результаты исследования
Глава 1. Исследование аналогов и постановка задач работы (противоречие и задача не формулируются)			
1	существующим информационным обеспечением проектной деятельности по управлению рисками серверной инфраструктуры Linux и необходимостью его совершенствования в части установления соответствий между угрозами эксплуатации ошибок конфигурирования сервисов, тактиками и техниками MITRE ATT&CK, эксплуатируемыми уязвимостями CVE и компенсационными мерами защиты	Создание информационного обеспечения, покрывающего потребности проектной деятельности работы в формализации угроз эксплуатации ошибок конфигурирования сервисов, сценариев атак в виде цепочек тактических звеньев «тактика – техника MITRE ATT&CK – уязвимость CVE» и соответствующих им компенсационных мер	Необходимое и достаточное для решения задач работы информационное обеспечение проактивных действий по защите серверной инфраструктуры Linux: дерево угроз и индуцированных рисков, граф сценариев атак на сервисы серверной инфраструктуры Linux
2	существующими методиками риск-анализа серверной инфраструктуры Linux и необходимостью их совершенствования в части проактивной оценки вероятности и ущерба реализации сценариев атак по каждому тактическому звену с учётом чувствительности риска к параметрам конфигурации сервисов	Создание аналитики проактивного риск-анализа нарушений ИБ серверной инфраструктуры Linux, учитывая вероятности успешного применения техник MITRE ATT&CK для эксплуатации уязвимостей CVE, ущерб от нарушения конфиденциальности, целостности и доступности информации и функции чувствительности риска сценария к параметрам конфигурации сервисов	Аналитическое обеспечение проактивной оценки рисков нарушения ИБ серверной инфраструктуры Linux при эксплуатации ошибок конфигурирования сервисов: методика расчёта риска сценария атаки по его тактическим звеньям, функции чувствительности риска к параметрам конфигурации и риск-ландшафт серверной инфраструктуры Linux
3	существующими методиками управления рисками нарушения ИБ серверной инфраструктуры Linux и необходимостью их совершенствования в части подбора компенсационных мер, снижающих вероятность эксплуатации уязвимостей и величину ущерба в тактических звеньях сценариев атак, с учётом альтернативности обновления программного обеспечения и компенсирующей перенастройки сервисов	Создание аналитики проактивного управления рисками нарушения ИБ серверной инфраструктуры Linux, предусматривающей компенсационные меры снижения вероятности и ущерба в каждом тактическом звене сценария атаки, выбор мер по максимуму коэффициента смягчения риска и первоочередную защиту уязвимостей, через которые проходит наибольшее число сценариев	Аналитическое обеспечение проактивной регулировки рисков нарушения ИБ серверной инфраструктуры Linux при эксплуатации ошибок конфигурирования сервисов: методика выбора компенсационных мер, расчёт остаточного риска и эффекта риск-регулирования, регламенты реагирования и ликвидации последствий по этапам MITRE ATT&CK
4	имеющимися средствами автоматизации оценки и регулирования рисков серверной инфраструктуры Linux и необходимостью их совершенствования для оценки эффективности предлагаемых технических решений в части сквозного расчёта рисков сценариев атак до и после применения компенсационных мер	Формирование средств автоматизации, заточенных под проактивный экспресс-анализ процессов оценки и регулирования рисков нарушения ИБ серверной инфраструктуры Linux для оценки эффективности предлагаемых мер защиты, с применением методов машинного обучения в качестве вспомогательного инструмента для прогнозирования критичности конфигурационных недостатков	Средства автоматизации предложенных методик оценки и регулирования рисков нарушения ИБ серверной инфраструктуры Linux. Оценка эффективности разработанных мер защиты серверной инфраструктуры Linux по снижению риска сценариев атак

Перушкин. Тема: Разработка интеллектуальной системы оценки и регулирования киберрисков серверной инфраструктуры Linux при эксплуатации ошибок конфигурирования сервисов

№	Новизна результатов	Практическая ценность результатов	Теоретическая ценность результатов
Глава 1. Исследование аналогов и постановка задач работы (противоречие и задача не формулируются)			
1	Предлагаемое информационное обеспечение проектной деятельности, в отличие от аналогов, обеспечивает сквозную привязку угроз эксплуатации ошибок конфигурирования сервисов к тактическим звеньям сценариев атак, эксплуатируемым в них уязвимостям CVE программного обеспечения сервисов и компенсационным мерам и ошибкам конфигурирования сервисов, делающим эти уязвимости эксплуатируемыми	Структура и состав предложенного информационного обеспечения ИБ-деятельности на объекте могут быть практически использованы при построении графа сценариев атак и выборе мер защиты серверной инфраструктуры Linux	Методики сбора и обработки данных, предложенные в работе, могут быть развиты применительно к иным операционным системам и сетевому оборудованию
2	Разработанная аналитика риск-анализа нарушений ИБ на объекте, в отличие от аналогов, учитывает влияние параметров конфигурации сервисов на вероятность эксплуатации известных уязвимостей и оценивает функциями чувствительности, изменение каких параметров сильнее всего меняет риск сценария атаки	На практике предложенные методики риск-анализа позволяют выделять наиболее вероятные и наиболее ущербные сценарии атак на серверную инфраструктуру Linux до их реализации и выделять параметры конфигурации, сильнее всего влияющие на риск	Разработанные методики риск-анализа целесообразно развить в части учёта организационных и процедурных недостатков и иных классов угроз
3	Разработанная аналитика управления ИБ-рисками на объекте, в отличие от аналогов, предусматривает сопоставление обновления программного обеспечения и компенсирующей перенастройки сервисов по коэффициенту смягчения риска в каждом тактическом звене, выбор мер по функциям чувствительности риска к их параметрам и очерёдность устранения уязвимостей по числу проходящих через них сценариев	Практическое применение предложенной аналитики управления ИБ-рисками видится в обосновании выбора и очерёдности внедрения мер защиты серверной инфраструктуры Linux, в том числе при невозможности оперативного обновления программного обеспечения	Перспективное развитие предложенной аналитики управления ИБ-рисками видится в расширении состава компенсационных мер и учёте взаимного влияния сервисов
4	Созданные средства автоматизации проектной ИБ-деятельности на объекте, в отличие от аналогов, позволяют выполнять полный цикл от построения графа сценариев атак по данным CVE и MITRE ATT&CK до расчёта первичного и остаточного риска, а вспомогательная модель машинного обучения дополняет исходные данные прогнозными оценками критичности конфигурационных недостатков	Созданные средства автоматизации проектной ИБ-деятельности на объекте практически необходимы для регулярного пересчёта рисков серверной инфраструктуры Linux при изменении конфигурации сервисов и состава пакетов	Теоретическая значимость созданного инструментария автоматизации проектной ИБ-деятельности видится в возможности его адаптации для иных операционных систем и классов угроз

Ширинкин. Тема: Разработка интеллектуальной системы оценки и регулирования киберрисков корпоративной DevOps-инфраструктуры при нарушении безопасности CI/CD-процессов

№	Противоречия между	Задачи исследования	Результаты исследования
Глава 1. Исследование аналогов и постановка задач работы (противоречие и задача не формулируются)			
1	существующим информационным обеспечением проектной деятельности по управлению рисками корпоративной DevOps-инфраструктуры и необходимостью его совершенствования в части установления соответствий между угрозами нарушения безопасности CI/CD-процессов, тактиками и техниками MITRE ATT&CK, эксплуатируемыми уязвимостями CVE и компенсационными мерами защиты	Создание информационного обеспечения, покрывающего потребности проектной деятельности работы в формализации угроз нарушения безопасности CI/CD-процессов, сценариев атак в виде цепочек тактических звеньев «тактика – техника MITRE ATT&CK – уязвимость CVE» и соответствующих им компенсационных мер	Необходимое и достаточное для решения задач работы информационное обеспечение проактивных действий по защите корпоративной DevOps-инфраструктуры: дерево угроз и индуцированных рисков, база соответствий «шаблон атаки CAPEC – тактика – техника MITRE ATT&CK – уязвимость CVE – компенсационная мера» и граф сценариев атак на этапы конвейера CI/CD
2	существующими методиками риск-анализа корпоративной DevOps-инфраструктуры и необходимостью их совершенствования в части проактивной оценки вероятности и ущерба реализации сценариев атак по каждому тактическому звену с учётом последовательного распространения компрометации по этапам конвейера	Создание аналитики проактивного риск-анализа нарушений ИБ корпоративной DevOps-инфраструктуры, учитывая вероятности успешного применения техник MITRE ATT&CK для эксплуатации уязвимостей CVE, ущерб от нарушения конфиденциальности, целостности и доступности информации и описание распространения компрометации по этапам конвейера разностными уравнениями	Аналитическое обеспечение проактивной оценки рисков нарушения ИБ корпоративной DevOps-инфраструктуры при нарушении безопасности CI/CD-процессов: методика расчёта риска сценария атаки по его тактическим звеньям, модель накопления риска по этапам конвейера на основе разностных уравнений и риск-ландшафт DevOps-инфраструктуры
3	существующими методиками управления рисками нарушения ИБ корпоративной DevOps-инфраструктуры и необходимостью их совершенствования в части подбора компенсационных мер, снижающих вероятность эксплуатации уязвимостей и величину ущерба в тактических звеньях сценариев атак, с учётом этапа конвейера, на котором мера прерывает распространение компрометации	Создание аналитики проактивного управления рисками нарушения ИБ корпоративной DevOps-инфраструктуры, предусматривающей компенсационные меры снижения вероятности и ущерба в каждом тактическом звене сценария атаки, выбор мер по максимуму коэффициента смягчения риска и первоочередную защиту уязвимостей, через которые проходит наибольшее число сценариев	Аналитическое обеспечение проактивной регулировки рисков нарушения ИБ корпоративной DevOps-инфраструктуры при нарушении безопасности CI/CD-процессов: методика выбора компенсационных мер, расчёт остаточного риска и эффекта риск-регулирования, регламенты реагирования и ликвидации последствий по этапам MITRE ATT&CK
4	имеющимися средствами автоматизации оценки и регулирования рисков корпоративной DevOps-инфраструктуры и необходимостью их совершенствования для оценки эффективности предлагаемых технических решений в части сквозного расчёта рисков сценариев атак до и после применения компенсационных мер	Формирование средств автоматизации, заточенных под проактивный экспресс-анализ процессов оценки и регулирования рисков нарушения ИБ корпоративной DevOps-инфраструктуры для оценки эффективности предлагаемых мер защиты, с применением методов машинного обучения в качестве вспомогательного инструмента для классификации конфигураций конвейеров из открытых репозиториев по уровню риска при формировании исходных данных	Средства автоматизации предложенных методик оценки и регулирования рисков нарушения ИБ корпоративной DevOps-инфраструктуры. Оценка эффективности разработанных мер защиты DevOps-инфраструктуры по снижению риска сценариев атак

Ширинкин. Тема: Разработка интеллектуальной системы оценки и регулирования киберрисков корпоративной DevOps-инфраструктуры при нарушении безопасности CI/CD-процессов

№	Новизна результатов	Практическая ценность результатов	Теоретическая ценность результатов
Глава 1. Исследование аналогов и постановка задач работы (противоречие и задача не формулируются)			
1	Предлагаемое информационное обеспечение проектной деятельности, в отличие от аналогов, обеспечивает сквозную привязку угроз нарушения безопасности CI/CD-процессов к тактическим звеньям сценариев атак, эксплуатируемым в них уязвимостям CVE компонентов конвейера (систем управления репозиториями, сборочных агентов, реестров артефактов) и компенсационным мерам с учётом этапов конвейера и секретов, через которые компрометация распространяется по цепочке поставки	Структура и состав предложенного информационного обеспечения ИБ-деятельности на объекте могут быть практически использованы при построении графа сценариев атак и выборе мер защиты корпоративной DevOps-инфраструктуры	Методики сбора и обработки данных, предложенные в работе, могут быть развиты применительно к процессам GitOps и иным видам атак на цепочку поставки программного обеспечения
2	Разработанная аналитика риск-анализа нарушений ИБ на объекте, в отличие от аналогов, учитывает комплексный характер атак на цепочку поставки, описывая риск на каждом этапе конвейера разностным уравнением через риск предыдущего этапа, вероятность успешного применения техники и ущерб от эксплуатации уязвимости	На практике предложенные методики риск-анализа позволяют выделять наиболее вероятные и наиболее ущербные сценарии атак на корпоративную DevOps-инфраструктуру до их реализации и определять этап конвейера, на котором накопленный риск достигает наибольшего значения	Разработанные методики риск-анализа целесообразно развить в части учёта межорганизационных цепочек поставки программного обеспечения
3	Разработанная аналитика управления ИБ-рисками на объекте, в отличие от аналогов, предусматривает выбор компенсационных мер по максимуму коэффициента смягчения риска с оценкой по разностной модели того, как мера на отдельном этапе конвейера снижает накопленный риск на всех последующих этапах, и первоочередную защиту узлов графа, через которые проходит наибольшее число сценариев	Практическое применение предложенной аналитики управления ИБ-рисками видится в обосновании выбора и очерёдности внедрения мер защиты корпоративной DevOps-инфраструктуры с учётом места меры в конвейере	Перспективное развитие предложенной аналитики управления ИБ-рисками видится в расширении состава компенсационных мер и сценариев нарушения безопасности конвейера
4	Созданные средства автоматизации проектной ИБ-деятельности на объекте, в отличие от аналогов, позволяют выполнять полный цикл от построения графа сценариев атак по данным CVE и MITRE ATT&CK до расчёта первичного и остаточного риска, а вспомогательная модель машинного обучения оценивает по реальным конфигурациям конвейеров частоту встречаемости недостатков, используемую при расчёте вероятностей	Созданные средства автоматизации проектной ИБ-деятельности на объекте практически необходимы для регулярной переоценки рисков корпоративной DevOps-инфраструктуры при изменении конфигурации конвейеров	Теоретическая значимость созданного инструментария автоматизации проектной ИБ-деятельности видится в возможности его адаптации для иных процессов разработки и классов угроз цепочки поставки